

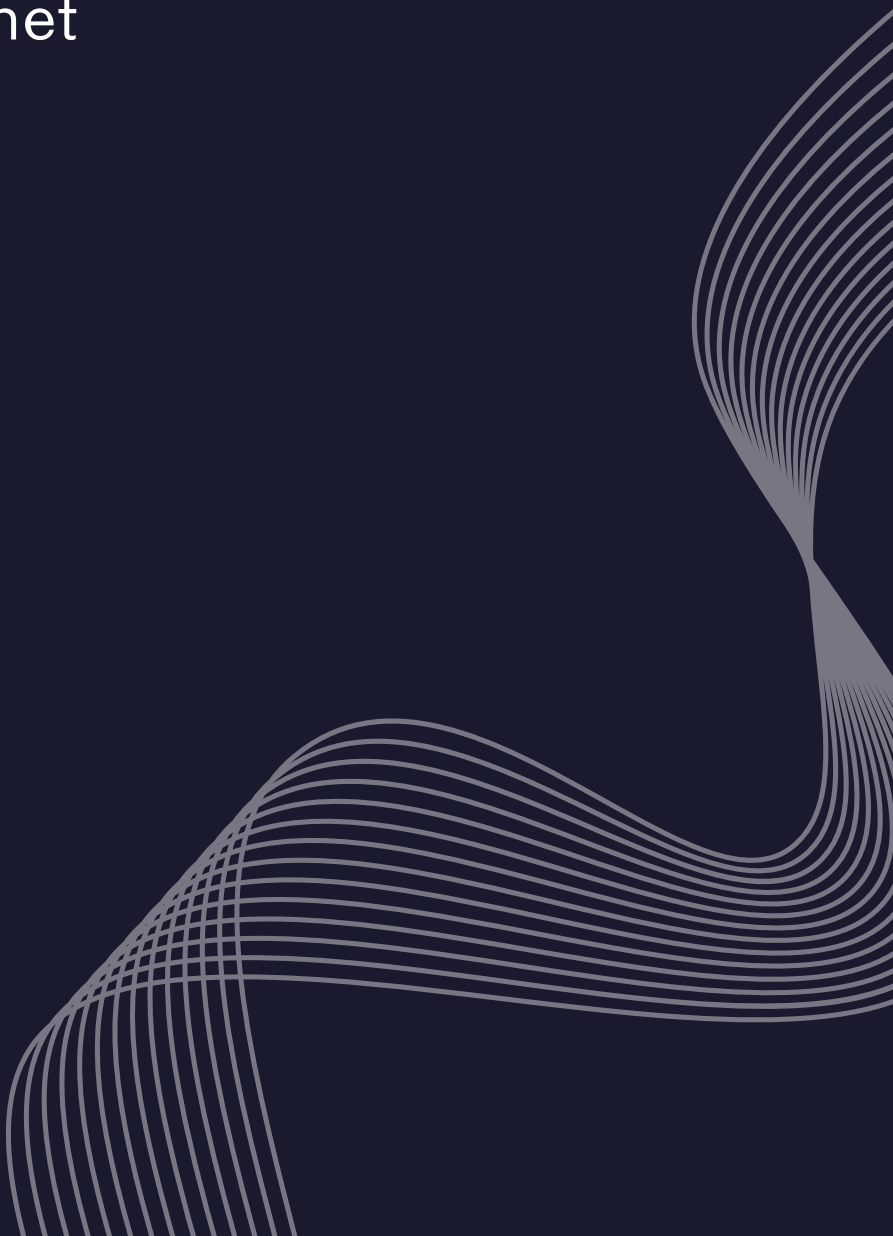
VULNERABILITY ASSESSMENT REPORT

for demo.testfire.net

SEPTEMBER 2026

Prepared by

Cybersecurity Intern



KEY FINDINGS AND RISK POSTURE

Medium

Overall Risk Classification Level

Risk Overview



High risk from
unencrypted
HTTP



Medium risk due
to missing
security headers

Scope & Methodology

How this assessment was conducted, and the ethical boundaries it followed

This assessment was limited to **public-facing pages** of demo.testfire.net and used only **passive, non-intrusive** techniques. No attempt was made to log in, bypass authentication, exploit a vulnerability, or otherwise disrupt the service. The objective was to identify and classify risk — not to demonstrate impact through attack.

Passive scanning

Header analysis

Service enumeration

Login bypass

Exploitation

Brute force

Denial of Service

TOOLS USED

Nmap

Identified open ports and running services (80, 443, 8080) without probing beyond standard service detection.

OWASP ZAP

Ran in passive scan mode to flag missing security headers and configuration weaknesses, with no active attack modules enabled.

Browser DevTools

Inspected response headers, cookies, and client-side configuration directly in the browser.

All testing was performed against a public demo/test domain intended for this type of exercise, in line with responsible-disclosure and read-only-audit practice. No credentials, personal data, or backend systems were accessed at any point.

Detailed Findings

Unencrypted HTTP and Security Headers

Unencrypted HTTP poses a significant risk to data integrity and confidentiality. As information is transmitted over this protocol, it is exposed to potential interception by malicious actors. Without encryption, sensitive data such as user credentials and personal information can be compromised, leading to unauthorized access and data breaches. This vulnerability requires immediate attention to ensure that secure protocols, such as HTTPS, are implemented across all endpoints to safeguard user data and maintain trust in the platform.

Missing security headers contribute to the overall vulnerability of demo.testfire.net. Essential headers, such as Content Security Policy (CSP) and X-Frame-Options, help protect against cross-site scripting (XSS) and clickjacking attacks. The absence of these security measures can leave the application susceptible to exploitation. Implementing these headers is crucial to enhancing security posture and mitigating risks associated with web application vulnerabilities. Immediate action is required to add these headers to strengthen the overall security framework of the application.

Outdated Component Disclosure

Server banner: Apache-Coyote/1.1

Nmap's service detection returned an **Apache-Coyote/1.1** banner on ports 80, 443 and 8080. Coyote is the HTTP connector used by Apache Tomcat, and this banner confirms the application is running on a Tomcat-based server. Beyond disclosing the software stack, an exposed version string tells an attacker exactly which product and generation to research for known weaknesses — turning a simple information leak into a starting point for a targeted attack.

This assessment did not attempt to fingerprint the exact Tomcat release or test for specific CVEs, as doing so falls outside the passive, read-only scope agreed for this engagement. However, because the underlying framework could not be confirmed as current, we recommend the client's engineering team independently verify the deployed Tomcat version against the latest supported release and apply any outstanding security patches, in addition to suppressing the banner itself.

Recommendation: Confirm the Tomcat/Coyote version against Apache's current support lifecycle, patch or upgrade if it is end-of-life, and disable version banners (*server.xml* → *remove/obscure the Server response header*) so the running software version is not advertised to unauthenticated visitors.

Risk Classification

Risk classification of vulnerabilities identified

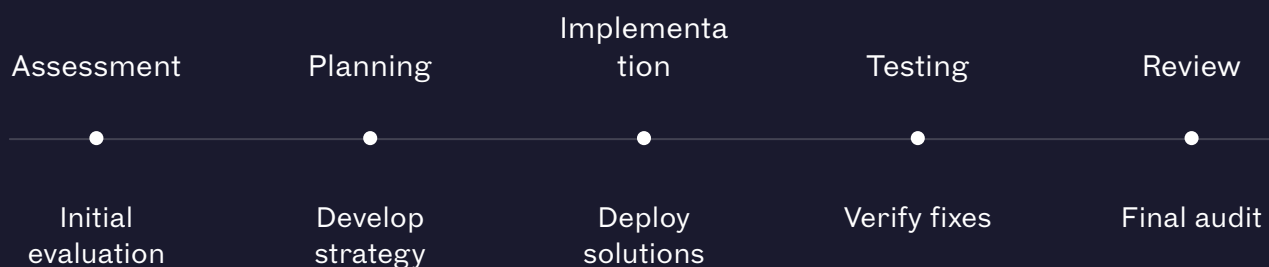
VULNERABILITY	SEVERITY	IMPACT SUMMARY	RECOMMENDATION
Unencrypted HTTP Protocol	High	Cleartext communication enables Man-in-the-Middle sniffing of credentials and data.	Deploy SSL/TLS certificate and enforce automatic HTTP-to-HTTPS redirect.
Missing Security Headers	Medium	Lack of X-Frame-Options, HSTS, and CSP increases Clickjacking and XSS risks.	Configure X-Frame-Options: SAMEORIGIN and Strict-Transport-Security.
Server Version Disclosure	Low	Apache-Coyote/1.1 banner header discloses exact software version.	Suppress server tokens and custom banner headers in server configuration.
Unnecessary Open Port (8080)	Low	Port 8080 exposed publicly alongside Port 80 increases attack surface.	Restrict Port 8080 via firewall rules to authorized management IPs only.

Vulnerabilities

Findings and Recommendations Overview

1. Immediate (0-7 Days): Enable HTTPS across all endpoints and redirect HTTP traffic.
 2. Short Term (7-14 Days): Add X-Frame-Options, HSTS, and nosniff security headers.
 3. Medium Term (14-30 Days): Restrict port 8080 access via firewall rules and disable server version banners
-
- Upgrade server OS
 - Conduct employee training
 - Improve monitoring tools
-
- Strengthen server security
 - Implement regular security audits
 - Enhance firewall settings

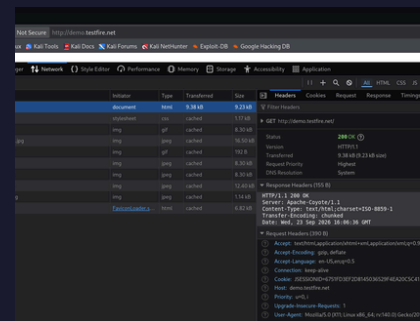
Remediation Timeline



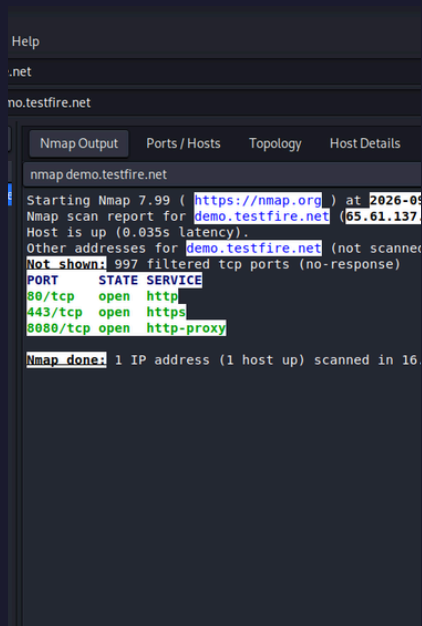
The remediation timeline outlines a **phased approach** to address vulnerabilities identified in the assessment of demo.testfire.net. Each phase focuses on critical steps that ensure a thorough and effective enhancement of security measures. Starting with an assessment to evaluate the current state, followed by planning to create a strategic response, the process continues with implementation of solutions, testing to confirm efficacy, and concludes with a comprehensive review to ensure all vulnerabilities have been adequately addressed. This systematic approach promotes resilience against future threats.

VULNERABILITY ASSESSMENT REPORT

```
(root@kali)~#  
# nmap -sV demo.testfire.net  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-09-23 12:10 -0400  
Nmap scan report for demo.testfire.net (65.61.137.117)  
Host is up (0.028s latency).  
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975  
Not shown: 997 filtered tcp ports (no-response)  
PORT      STATE SERVICE VERSION  
80/tcp    open  http      Apache Tomcat/Coyote JSP engine 1.1  
443/tcp   open  ssl/http  Apache Tomcat/Coyote JSP engine 1.1  
8080/tcp  open  http      Apache Tomcat/Coyote JSP engine 1.1  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 51.56 seconds
```



Host	Port	State	Service	Version
demo.testfire.net	80	open	http	Apache Tomcat/Coyote JSP engine 1.1
demo.testfire.net	443	open	ssl/http	Apache Tomcat/Coyote JSP engine 1.1
demo.testfire.net	8080	open	http	Apache Tomcat/Coyote JSP engine 1.1



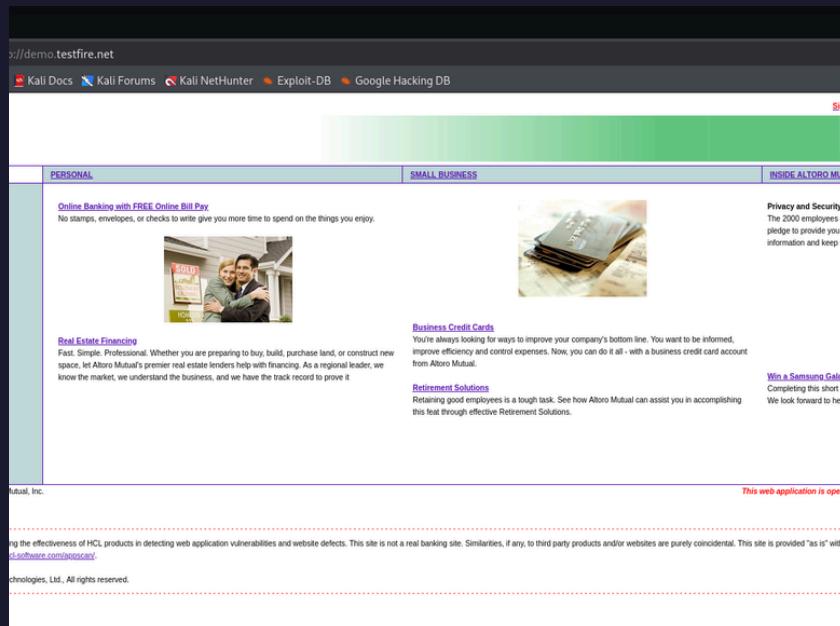
Help
demo.testfire.net
no.testfire.net

Nmap Output Ports / Hosts Topology Host Details

nmap demo.testfire.net

Starting Nmap 7.99 (https://nmap.org) at 2026-09-23 12:10 -0400
Nmap scan report for demo.testfire.net (65.61.137.117)
Host is up (0.035s latency).
Other addresses for demo.testfire.net (not scanned): 64:ff9b::413d:8975
Not shown: 997 filtered tcp ports (no-response)
PORT STATE SERVICE VERSION
80/tcp open http Apache Tomcat/Coyote JSP engine 1.1
443/tcp open ssl/http Apache Tomcat/Coyote JSP engine 1.1
8080/tcp open http Apache Tomcat/Coyote JSP engine 1.1

Nmap done: 1 IP address (1 host up) scanned in 16.56 seconds



demo.testfire.net

Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB

PERSONAL SMALL BUSINESS INSIDE ALTORO MUTUAL

Online Banking with FREE Online Bill Pay
No stamps, envelopes, or checks to write give you more time to spend on the things you enjoy.

Real Estate Financing
Fast. Simple. Professional. Whether you are preparing to buy, build, purchase land, or construct new space, let Altoro Mutual's premier real estate lenders help with financing. As a regional leader, we know the market, we understand the business, and we have the track record to prove it.

Business Credit Cards
You're always looking for ways to improve your company's bottom line. You want to be informed, improve efficiency and control expenses. Now, you can do it all - with a business credit card account from Altoro Mutual.

Retirement Solutions
Retaining good employees is a tough task. See how Altoro Mutual can assist you in accomplishing this feat through effective Retirement Solutions.

Privacy and Security
The 2000 employees of Altoro Mutual pledge to provide you with the highest level of privacy and security for your information and keep it safe.

Win a Samsung Galaxy S21
Completing this short survey is your chance to win a Samsung Galaxy S21. We look forward to hearing from you.

This web application is open

Altoro Mutual, Inc.

ing the effectiveness of HCL products in detecting web application vulnerabilities and website defects. This site is not a real banking site. Similarities, if any, to third party products and/or websites are purely coincidental. This site is provided "as is" with no warranty. [HCL Software.com/privacy](#)

Altoro Mutual, Inc. All rights reserved.

Visual Evidence

This section presents visual evidence of identified vulnerabilities, showcasing screenshots and images that highlight security risks associated with demo.testfire.net.

Summary & Next Steps

Overall risk posture and closing recommendation



demo.testfire.net carries an overall **Medium** risk classification. The single High-severity issue — unencrypted HTTP — is the primary driver of that rating, since it directly exposes credentials and other sensitive data to interception. The Medium-severity gap in security headers compounds this by leaving the application more open to clickjacking and cross-site scripting. The two Low-severity items (version disclosure and an unnecessary open port) do not pose an immediate threat on their own but widen the attack surface and are inexpensive to fix.

None of the issues identified require complex engineering work. Enforcing HTTPS and adding the missing security headers — both achievable within the first two weeks — would resolve the two most significant risks and move the site to a substantially stronger security posture. We recommend the remediation timeline on page 6 be treated as the priority order for engineering work, with a follow-up scan after implementation to confirm each fix.

This report reflects a point-in-time, passive assessment. It is not a substitute for a full penetration test and does not guarantee the absence of vulnerabilities beyond what was observable through non-intrusive testing.